

UNIVERSIDADE ESTADUAL DE MONTES CLAROS – UNIMONTES
CENTRO DE CIÊNCIAS EXATAS E TECNOLÓGICAS – CCET
DEPARTAMENTO DE CIÊNCIAS DA COMPUTAÇÃO – DCC

PESQUISA DE CRIMES VIRTUAIS DE 2024 A 2026

ERIC SILVA GUSMÃO

RAMON LOPES DE QUEIROZ

MONTES CLAROS – MG
SETEMBRO / 2026

ERIC SILVA GUSMÃO

RAMON LOPES DE QUEIROZ

PESQUISA DE CRIMES VIRTUAIS DE 2024 A 2026

Atividade avaliativa apresentada para
atendimento de requisito parcial para
aprovação na disciplina Gestão de
informação do Curso de Graduação em
Bacharelado em Sistemas de Informação
– 3º período

Professor(a): Marilee Patta

MONTES CLAROS – MG

SETEMBRO / 2026

Caso 1: Ataque de Ransomware no Grupo Jorge Batista (maio de 2025)

O que aconteceu:

Em maio de 2025, o Grupo Jorge Batista — um dos maiores conglomerados atacadistas do Brasil nos setores farmacêutico e alimentício — tornou-se vítima de um dos ataques cibernéticos mais graves do setor logístico nacional. O incidente foi articulado pelo grupo hacker denominado **Gunra**, que utilizou uma tática avançada de ransomware baseada em **dupla extorsão**.

O ataque comprometeu a infraestrutura de TI do grupo ao criptografar os sistemas operacionais e, simultaneamente, exfiltrar um volume massivo de dados. Ao todo, cerca de **4,2 terabytes de dados confidenciais** foram roubados dos servidores da empresa. A estratégia de dupla extorsão baseou-se em duas frentes de pressão: o bloqueio imediato das operações cotidianas da distribuidora e a ameaça de vazamento público das informações confidenciais caso o resgate solicitado não fosse quitado.

Sob a perspectiva da Segurança da Informação, o incidente afetou diretamente a **Informação Operacional-Chave** do conglomerado. A paralisação dos sistemas interrompeu o fluxo de suprimentos, impedindo a distribuição de itens essenciais como medicamentos e gêneros alimentícios. Os prejuízos financeiros e operacionais resultantes dessa paralisação ultrapassaram a marca de **R\$ 400 milhões**.

Caso 2: Fraude bilionária no Pix via C&M Software (julho de 2025)

O que aconteceu

A C&M Software, empresa de tecnologia que atua como intermediária entre instituições financeiras e o sistema do Banco Central (incluindo o Pix), foi vítima de uma fraude sofisticada do tipo "ataque à cadeia de suprimento". Um funcionário terceirizado vendeu suas credenciais de acesso legítimas a criminosos por apenas R\$ 15 mil.

Com essas credenciais, o grupo criminoso acessou as chamadas contas de reserva — contas que os bancos mantêm no Banco Central para garantir liquidez e liquidar transações entre si, que não pertencem diretamente a clientes finais. Os criminosos simularam transferências legítimas via Pix e desviaram os recursos para contas próprias, convertendo parte do dinheiro em criptomoedas (Bitcoin, Ethereum, USDT) por meio de corretoras latino-americanas, dificultando o rastreamento. Pelo menos seis instituições financeiras foram afetadas, incluindo BMP, Credsystem e Banco Paulista.

O resultado foi um prejuízo direto estimado entre R\$ 800 milhões e R\$ 1 bilhão, considerado o maior desvio cibernético já registrado no sistema financeiro brasileiro, levando a Justiça a determinar o bloqueio de até R\$ 640 milhões em bens dos investigados, além de R\$ 270 milhões em contas usadas para receber os valores desviados. O Banco Central chegou a suspender temporariamente o acesso da C&M ao sistema Pix, paralisando operações das instituições conectadas durante a investigação inicial.

O caso também gerou a "Operação Magna Fraus" da Polícia Federal, com mandados de busca e prisão contra 26 suspeitos em sete estados por organização criminosa, invasão de dispositivo informático, furto mediante fraude eletrônica e lavagem de dinheiro, além de expor uma fragilidade crítica na cadeia de segurança do sistema financeiro nacional — não no núcleo do Banco Central, mas nos prestadores de serviço terceirizados que conectam instituições menores ao Pix.

Caso 3: Ataque à Microsoft pelo grupo Midnight Blizzard (Janeiro de 2024)

Em 19 de janeiro de 2024, a Microsoft revelou ter sido alvo de um ataque hacker patrocinado pelo Estado russo. Os hackers acessaram caixas de correio eletrônico da alta administração, vazando dados confidenciais.

O agente da ameaça:

- Midnight Blizzard : Um grupo de ameaças cibernéticas patrocinado pelo Estado russo, também conhecido como Nobelium, CozyBear e APT29.
- Outras violações de segurança notáveis da Midnight Blizzard: Hewlett Packard Enterprise e SolarWinds
- Alvo do ataque: ambiente Entra ID da Microsoft (o Microsoft Entra ID é uma solução de gerenciamento de identidade e acesso (IAM) baseada em nuvem que oferece aos usuários uma experiência de login único, independentemente de seus aplicativos estarem na nuvem ou em infraestruturas locais).
- Estratégias utilizadas: Ataques de força bruta (uma técnica em que um atacante tenta usar a mesma senha em várias contas antes de tentar outra), exploração de identidades e configurações incorretas de SaaS.
- Consequências: O ambiente Entra ID comprometido resultou em acesso não autorizado às contas de e-mail da equipe de liderança sênior da Microsoft, da equipe de segurança, da equipe jurídica e de outros.

Anatomia do ataque:

Os atacantes por trás da violação de segurança da Microsoft demonstraram um profundo conhecimento dos mecanismos do OAuth e das técnicas de exploração, o que lhes permitiu contornar os controles de detecção com eficácia. Ao criar aplicativos maliciosos e manipular as permissões do OAuth, eles obtiveram acesso irrestrito às caixas de correio do Office 365 Exchange, facilitando a exfiltração de dados confidenciais com alarmante facilidade.

Desafios de Segurança:

Táticas centradas na identidade

A estratégia da Midnight Blizzard visa explorar credenciais de usuários como porta de entrada para dados sensíveis representa um obstáculo formidável, tornando os controles de detecção tradicionais inadequados.

Abuso de aplicativos OAuth

O uso abusivo de aplicações OAuth complica os esforços de detecção, permitindo que os atacantes mantenham uma persistência prolongada em ambientes visados.

Análise passo a passo:

Preparação Pré-Invasão

Antes de iniciar o ataque, o invasor utilizou um aplicativo OAuth no ambiente de teste da Microsoft, concedendo-lhe inadvertidamente privilégios elevados. Essa falha evidencia o desafio de gerenciar ambientes de aplicativos complexos e as consequentes configurações incorretas.

Estratégia de Acesso Inicial

Por meio de esforços de reconhecimento, a Midnight Blizzard teve como alvo o cliente de teste, explorando uma senha fraca e fácil de adivinhar na conta de administrador, que não possuía autenticação multifator (MFA). Empregando técnicas como ataques de força bruta e proxies residenciais, o invasor obteve acesso não autorizado, evidenciando as limitações dos mecanismos tradicionais de detecção de ameaças.

Estratégias de Persistência

O atacante manipulou as permissões do OAuth para obter controle sobre a conta de administrador, assumindo o controle do aplicativo OAuth em todas as instalações. Essa tática espelha técnicas observadas em ataques anteriores, enfatizando a necessidade de monitoramento contínuo para detectar e impedir alterações maliciosas prontamente.

Manobras de Escalada de Privilégios

Explorando as permissões do TestApp, o atacante elevou seus privilégios criando um novo usuário, provavelmente um administrador. A implantação subsequente de aplicativos OAuth maliciosos adicionais consolidou ainda mais sua posição, ressaltando a importância de medidas proativas para identificar e mitigar pontos cegos baseados em configurações.

Movimento lateral e comprometimento de dados

Apesar das incertezas quanto ao número e à origem dos aplicativos instalados, as evidências sugerem que a exploração do TestApp pelo invasor facilitou o acesso não autorizado a caixas de correio críticas dentro da hierarquia corporativa da Microsoft.

Caso 4: Megavazamento do National Public Data (Abril a Julho de 2024)

A National Public Data (NPD) — operada pela empresa Jerico Pictures, Inc. — é uma corretora de dados privada que agrega e vende acesso a registros pessoais. Não se trata de uma agência governamental nem de uma infraestrutura governamental. É um serviço comercial de verificação de antecedentes e corretagem de dados, que possuía um enorme banco de dados de informações pessoais compiladas a partir de diversas fontes públicas e privadas.

Em 2024, esse banco de dados foi acessado sem autorização e colocado à venda. A violação expôs informações de identificação pessoal (PII), incluindo nomes, números de Seguro Social, endereços e números de telefone — muitas delas sem criptografia para protegê-las em repouso.

Quando ocorreu a violação de dados públicos nacionais?

As evidências indicam que os dados foram obtidos dos sistemas do NPD possivelmente já no final de 2023. A violação tornou-se pública em abril de 2024, quando um agente malicioso usando o pseudônimo USDoD listou os dados roubados para venda no BreachForums, anunciando cerca de 2,9 bilhões de registros. Um vazamento mais amplo ocorreu em agosto de 2024, quando outro agente disponibilizou gratuitamente uma parte significativa dos dados — momento em que o caso recebeu ampla cobertura da mídia e levou o NPD a divulgar publicamente os dados.

Quem invadiu o sistema hackeado da National Public?

O grupo de ameaças USDoD reivindicou a responsabilidade por obter e divulgar os dados no BreachForums em abril de 2024. Além disso, o quadro completo de como o acesso foi obtido e se outras partes estiveram envolvidas permanece obscuro, com base em informações públicas. Não foi possível confirmar a atribuição a um grupo de ameaças persistentes avançadas (APT).

Como ocorreu a violação dos dados públicos nacionais?

Com base nas informações disponíveis publicamente, a violação parece ter envolvido acesso não autorizado ao banco de dados da NPD — e não uma intrusão em várias etapas envolvendo phishing, malware personalizado e movimentação lateral em redes corporativas. O método técnico específico de acesso inicial não foi confirmado publicamente em detalhes pela NPD ou pelos investigadores.

O que ficou claro é que a empresa detinha um volume extraordinariamente grande de dados pessoais sensíveis com proteções insuficientes. Um banco de dados contendo registros de centenas de milhões de pessoas é um alvo de alto valor, e os controles implementados não eram adequados para protegê-lo.

Cronologia nacional de violações de dados públicos

Final de 2023 (estimativa) – Acredita-se que os dados tenham sido obtidos dos sistemas da NPD.

Abril de 2024 – O agente de ameaças USDoD lista aproximadamente 2,9 bilhões de registros para venda no BreachForums.

Agosto de 2024 – Grande parte dos dados é publicada gratuitamente online; segue-se uma ampla cobertura da mídia.

Agosto de 2024 – A NPD reconhece publicamente a violação de dados e começa a notificar os indivíduos afetados.

Final de 2024 – A Jerico Pictures, Inc. entra com pedido de falência; as operações da NPD são encerradas.

Detalhes técnicos

A violação envolveu acesso não autorizado ao banco de dados da NPD e exfiltração de registros em larga escala. Nenhum relato público confiável confirmou o uso de phishing, malware sofisticado para persistência ou movimentação lateral por meio de

credenciais administrativas roubadas como metodologia de ataque. Os dados parecem ter sido obtidos por meio de acesso direto ao banco de dados, embora o vetor técnico exato não tenha sido confirmado publicamente.

Investigadores independentes foram contratados após a divulgação pública. As conclusões apontaram para lacunas significativas na forma como os dados eram armazenados e protegidos — particularmente a falta de criptografia em campos sensíveis e controles de acesso inadequados em torno do banco de dados.

Que dados foram comprometidos na violação de segurança pública nacional?

Os dados roubados incluíam nomes, números de Segurança Social, endereços e números de telefone. Grande parte dessas informações não estava criptografada. Os registros parecem ter sido agregados a partir de fontes públicas e feeds de corretoras de dados, o que significa que os dados foram rastreados até pessoas em todos os Estados Unidos, mesmo que elas nunca tenham interagido diretamente com o National Public Data.

Quantas pessoas foram afetadas pela violação de dados públicos nacionais?

Embora o número exato permaneça incerto, estima-se que mais de um bilhão de pessoas foram afetadas direta ou indiretamente pela violação de segurança.

Principais impactos da violação do Sistema Nacional de Segurança Pública

A violação causou paralisações significativas nas atividades comerciais, perdas financeiras e danos à reputação das organizações afetadas. Agências governamentais enfrentaram críticas públicas e a confiança nas práticas de segurança de dados diminuiu.

Resposta à violação de dados públicos nacionais

Após a descoberta, as organizações coordenaram ações com autoridades como o FBI e a CISA para conter o ataque. Avisos públicos e planos de resposta a incidentes foram implementados para mitigar riscos adicionais.

O sistema National Public está seguro após a violação de segurança?

Após o incidente, os sistemas afetados passaram por atualizações significativas, incluindo monitoramento aprimorado e avaliações de vulnerabilidade. Especialistas

acreditam que as medidas de mitigação reduziram os riscos imediatos, embora a vigilância contínua seja essencial.

Caso 5: Invasões em massa no ecossistema Snowflake (Maio de 2024)

A violação de dados da Snowflake foi divulgada publicamente no final de maio de 2024. Em vez de explorar uma vulnerabilidade na plataforma da Snowflake, os agentes maliciosos usaram credenciais roubadas — coletadas por malwares de roubo de informações como Vidar, RISEPRO e LummaC2 — para acessar diretamente os tenants de clientes da Snowflake que não tinham autenticação multifator (MFA) ativada. A infraestrutura da própria Snowflake não foi comprometida. Investigações da Mandiant (Google) e da CrowdStrike confirmaram que a campanha foi uma operação de apropriação de contas em larga escala baseada em credenciais, visando ambientes de dados em nuvem corporativos. Isso levou à exposição de dados de clientes, incluindo registros financeiros e informações de identificação pessoal (PII). A campanha é uma das maiores intrusões em nuvem baseadas em credenciais já registradas, afetando aproximadamente 165 organizações clientes da Snowflake.

Quando ocorreu a violação de dados da Snowflake?

Infecções por malware Infostealer, que coletam credenciais da Snowflake, datam de pelo menos 2020 em alguns casos identificados. A campanha ativa de exfiltração contra vítimas específicas começou de fato em abril de 2024 e se estendeu até junho de 2024. A Snowflake, a Mandiant e a CrowdStrike divulgaram informações públicas coordenadas no final de maio de 2024, após detectarem o padrão de acesso não autorizado em diferentes clientes.

Quem hackeou o Snowflake?

Os ataques foram atribuídos a um grupo de ameaças rastreado pela Mandiant como UNC5537 — um grupo de cibercriminosos com motivação financeira que adquiria sistematicamente credenciais roubadas de registros de malware de roubo de

informações e as utilizava para acessar repositórios de dados na nuvem. O principal indivíduo associado ao UNC5537 operava sob o pseudônimo online "Judische". Alexander "Connor" Moucka (também conhecido como Judische) foi preso no Canadá em 30 de outubro de 2024, a pedido das autoridades americanas. Um cúmplice, John Binns, foi preso separadamente na Turquia. O Departamento de Justiça dos EUA tornou pública uma acusação federal contra Moucka e Binns em novembro de 2024.

Cronologia da violação de dados da Snowflake

2020–2024: Malwares de roubo de informações (Vidar, RISEPRO, LummaC2 e outros) infectaram dispositivos de funcionários de clientes da Snowflake, coletando credenciais salvas de tenants da Snowflake. Os registros de credenciais roubadas foram posteriormente adquiridos e usados pelo grupo UNC5537.

Abril–Junho de 2024: O UNC5537 realizou exfiltração ativa de dados de aproximadamente 165 organizações clientes da Snowflake, incluindo Ticketmaster/Live Nation, Santander Bank, AT&T, Advance Auto Parts, Pure Storage e Neiman Marcus, entre outras.

Final de maio de 2024: A Snowflake, em coordenação com a Mandiant e a CrowdStrike, divulgou publicamente a campanha. A Snowflake confirmou que sua própria plataforma não havia sido comprometida. A causa principal identificada foi a ausência de autenticação multifator (MFA) obrigatória nas contas dos clientes.

30 de outubro de 2024: Alexander "Connor" Moucka (também conhecido como Judische) foi preso no Canadá a pedido dos EUA para fins de extradição.

Novembro de 2024: O Departamento de Justiça dos EUA tornou pública uma acusação federal contra Moucka e John Binns em conexão com a campanha.

Detalhes técnicos

Os atacantes usaram credenciais roubadas — obtidas a partir de registros de malware de roubo de informações comprados ou adquiridos em mercados criminosos — como vetor de acesso inicial. Como um grande número de contas de clientes da Snowflake afetadas não tinha autenticação multifator (MFA) obrigatória, nomes de usuário e senhas válidos foram suficientes para autenticar diretamente nos ambientes de tenants da Snowflake. Após obterem acesso, eles se movimentaram lateralmente dentro dos tenants dos clientes e realizaram uma

significativa exfiltração de dados. Nenhuma porta dos fundos foi implantada na infraestrutura compartilhada da Snowflake; o acesso foi feito inteiramente por meio de autenticação legítima usando credenciais comprometidas.

Investigação de Incidentes

Tanto a Mandiant quanto a Snowflake declararam explicitamente que nenhuma vulnerabilidade no produto ou plataforma da Snowflake foi explorada nesta campanha. Investigações forenses independentes confirmaram que a causa raiz foi o roubo de credenciais por meio de infecções por malware do tipo "infostealer" em dispositivos gerenciados pelos clientes, combinado com a ausência de autenticação multifator (MFA) nas contas Snowflake dos clientes. A Snowflake foi posteriormente criticada por não exigir MFA por padrão e, após o incidente, anunciou medidas para tornar a MFA obrigatória para as contas dos clientes. Auditorias também revelaram que práticas inadequadas de registro de logs em alguns tenants afetados atrasaram a detecção inicial e a resposta ao incidente.

Quais dados foram comprometidos na violação de segurança da Snowflake?

Os dados expostos variaram de acordo com a organização, mas incluíram informações pessoais identificáveis (PII), como nomes completos, endereços, números de telefone e registros financeiros. No caso da AT&T, metadados de chamadas e mensagens de texto de aproximadamente 110 milhões de clientes foram roubados. O conjunto de dados roubado da Ticketmaster incluía nomes de clientes, endereços e dados parciais de cartões de pagamento de aproximadamente 560 milhões de pessoas. Alguns arquivos estavam criptografados, mas, nos clientes afetados, os invasores tinham acesso total de leitura, compatível com os privilégios das credenciais de conta comprometidas usadas para autenticação.

Quantas pessoas foram afetadas pela violação de dados da Snowflake?

Foi confirmado que aproximadamente 165 organizações clientes da Snowflake tiveram seus tenants da Snowflake acessados sem autorização. O número total de registros individuais de consumidores roubados nessas organizações chega às centenas de milhões — somente a AT&T foi responsável por aproximadamente 110 milhões de registros, e a Ticketmaster/Live Nation por cerca de 560 milhões.

Principais impactos da ruptura da camada de gelo Snowflake

A violação causou danos financeiros e de reputação significativos em dezenas de grandes empresas. AT&T, Ticketmaster e Santander enfrentaram escrutínio regulatório, obrigações de notificação aos clientes e, em alguns casos, processos judiciais. Os efeitos se estenderam à própria Snowflake, que passou a ser questionada sobre suas configurações de segurança padrão e a capacidade de seus clientes de impor a autenticação multifator (MFA). Os clientes questionaram a segurança das plataformas em nuvem de forma mais ampla, e o incidente reacendeu o debate no setor sobre modelos de responsabilidade compartilhada em ambientes de nuvem.

Resposta à violação de dados da Snowflake

A Snowflake divulgou prontamente a violação, coordenou ações com as autoridades policiais e empresas de cibersegurança e implementou correções de emergência para resolver a vulnerabilidade explorada.

A Snowflake está segura após a violação de segurança?

Desde então, a Snowflake reforçou sua postura de segurança implementando controles para exigir autenticação multifator (MFA) para contas de clientes e aprimorando os recursos de monitoramento

Referências Bibliográficas:

DANIELSON, L. National Public Data Breach: What Happened, Impact, and Lessons. **Huntress**, 31 out. 2025. Disponível em: <https://www.huntress.com/threat-library/data-breach/national-public-data-breach>. Acesso em: 7 set. 2026.

DANIELSON, L. Snowflake Data Breach: What Happened, Impact, and Lessons. **Huntress**, 12 nov. 2025. Disponível em: <https://www.huntress.com/threat-library/data-breach/snowflake-data-breach>. Acesso em: 7 set. 2026.

CORE TO CLOUD. Unraveling the Midnight Blizzard Attack on Microsoft. **Core to Cloud**, [2024?]. Disponível em: <https://www.coretocloud.co.uk/unraveling-the-midnight-blizzard-attack-on-microsoft/>. Acesso em: 7 set. 2026.